

OLOS — P1 & Hotfix-Debt Strategy

Evidence, reasoning, and a sequenced remediation plan

2026-08-09

1. Purpose and method

This document compiles (a) the open and *should-be-open* P1 issues, (b) the debt accrued through the July–August hotfix cycle, and (c) a forward strategy sized for a two-to-four-person volunteer team. Every claim cites a commit SHA, PR/issue number, or `file:line`; all evidence is reproducible from the read-only audit on branch `claude/olos-reentry-audit-8bglhk` (`olos-recon/2026-07-24/`, lane files 01–14). Citations marked *unverified* could not be confirmed from the repository or GitHub alone. Nothing here has been changed in the codebase; this is analysis only.

2. The P1 queue

Two P1s are open and untouched since 2026-07-11; four more meet the P1 bar but were never filed. Each entry: evidence, why it is high priority, and the recommended fix.

2.1 #213 — Revocation enforcement has never fired

severity: high, effort: S

Evidence. The cron schedule was removed “temporarily” on 2026-05-31 (commit 4361f91, “fix(ops): temporarily remove revocation-check cron schedule”); `vercel.json` today registers five crons and no `revocation-check`; the route exists and was rewritten twice, most recently in #348 where it became the *sole* writer of the `inactive` enrollment status (migration `00099_enrollment_registered_status.sql`: the reconciler is narrowed to `registered↔active` transitions). Open p1 #213, unassigned, its own body now stale (it cites a deleted cron and docs that exist only on an unmerged branch). **Why now.** After #348, no code path in the system moves anyone to `inactive`. Enrollment enforcement is fully dark on a live cohort, and drift compounds until the next cycle boundary. **Fix.** Decide cadence and labs semantics (the `warn→revoke` counts pod memberships lab-agnostically — confirm against the sub-cohort model in `docs/LOCAL_LABS.md`); add the `vercel.json` entry behind a dry-run flag; run one cohort week in dry-run, review output, then enable. Pairs with §2.4.

2.2 #212 — Metro-blind registration routing

severity: high, effort: S–M

Evidence. Open p1 #212 cites `docs/EVOLUTION.md`, migrations 00038/00039, and `getRegistrationCycle()` in `lib/cycles/registration.ts` — *none of which exist on mainline*: the docs live only on the unmerged branch `claude/olos-dev-pod-project-creation-uz3wez`, the migration numbers mean different files on `dev`, and a repo-wide grep finds no `getRegistrationCycle` (audit lane 06-lane-docs.md). **Why now.** The underlying concern — registration ignoring the participant’s lab — is a correctness issue for the next cohort’s routing, but the issue as written cannot be executed against current code. **Fix.** Re-anchor the issue to the real funnel (`app/api/registrations/funnel/route.ts`) and the shipped labs model (00062/00067/00068); then make the product call it defers: show HQ-open cycles only, or HQ-open plus local with labels.

2.3 Unfiled: blind-voting authorship leak

severity: high, effort: S

Evidence. Flagged in #117’s closing comment (id 4941719186, 2026-07-11): `GET /api/pods/[pod_id]/solution-proposals` is `withAuth-only` and returns `participant_id` on every proposal, so any authenticated pod member can derive who submitted what during blind voting; the comment itself says it “may deserve extraction as its own small p1 fix.” No issue was ever filed; none of the 14 open issues covers it (lane 02-lane-issues.md §1). By contrast, the new proposal gallery deliberately preserves no-author-attribution (`app/(dashboard)/cycles/[cycle_id]/proposals/page.tsx:24`) — the convention exists; this endpoint predates it. **Why now.** Voting integrity on a live platform; the finding is already 4 weeks old and survives only in a closed issue’s comment. **Fix.** File it; strip or alias `participant_id` from the member-facing payload during the voting window (admin/moderator surfaces may keep it). One route, unit-testable.

2.4 Unfiled: cron authentication fails open

severity: high (config-dependent), effort: S

Evidence. All six cron routes compare the header to `Bearer ${process.env.CRON_SECRET}` with no unset guard (e.g. `app/api/cron/learning-log-reminder/route.ts:35`); if the env var is missing, the literal string `Bearer undefined` authenticates a route that runs with the service-role client and sends email. `CRON_SECRET` is absent from `.env.local.example` and from `docs/environments.md`'s env lists (lane 07-lane-ops.md §3), so leaving it unset in a new environment is the default outcome. Whether it is set in Vercel prod is *unverified*. **Fix.** Three lines per route (or one shared guard): 401 when `CRON_SECRET` is unset; add the var to `.env.local.example`; confirm it is set in both Vercel environments. Do this before §2.1 schedules a seventh cron.

2.5 Unfiled: erasure RPC cannot erase role-holders

severity: high, effort: S

Evidence. `docs/AUTH_UNIFICATION_RUNBOOK.md:171-178`: `delete_participant()` omits `lab_leads` and `project_roles`, so erasing anyone holding those roles fails on foreign keys — “Fix ... before relying on erasure in prod.” Consciously deferred, never tracked (lane 06-lane-docs.md, ADR-4). Related, from the prod cutover record (unmerged branch `claude/dev-prod-migration-plan-5pumez`, commit 8a967dd): `participant_erasures` was created without row-level security anywhere in the chain (`supabase/migrations/00058_admin_roles_and_erasure.sql:74`) while `00015_grant_role_privileges.sql` default-grants broad access on future tables; prod was hand-fixed at cutover, but the fix exists in no migration, so dev/local/fresh builds regress. **Why now.** Right-to-erasure is the compliance backstop for a live alpha holding real participant data; today it would fail exactly for the most involved participants. **Fix.** One migration adding the two deletes to the RPC *and* codifying the prod-only fixes (`participant_erasures` RLS; `participants_insert` tightened to `auth_user_id = auth.uid()` — the chain version at 00002:55 is `WITH CHECK (true)`). File the tracking issue first.

2.6 Ratify or contest “owner decision O2”

severity: medium-high, effort: decision only

Evidence. Migration `00100_access_revocations_fresh_rows.sql` (landed in #348) drops the 00030 idempotency unique index on `access_revocations` so re-revocations write fresh audit rows; the rationale exists only as “owner decision O2” in a PR body (lane 13-lane-code-0809.md §1). Open issue #125 — move `reactivated` rows out of the table, options A/B/C — assumed the index that no longer exists and is now doubly stale. **Fix.** A 30-minute ratification: confirm O2 (then resolve #125 accordingly and document the semantics in `SCHEMA.md`, which does not yet note 00100) or contest it (then a follow-up migration restores a scoped constraint). Either outcome closes #125.

3. Hotfix-accrued debt: the catalog

The 07-25→08-04 window shipped 58 PRs (#303–#360) with zero reviews and, from #318 onward, a single person authoring *and* merging everything (lane 12-lane-github-0809.md §3). Each debt item below names the failure, the receipts, the cost paid, and the structural cause.

3.1 The re-land tax

#311, #312, #313 sat unreviewed 4–6 days, went stale against fast-moving `dev`, were closed unmerged, and were re-reported as #342, #344, #348 — with migrations renumbered because *all three had claimed 00092*. The original #313 carried a defect that would have **mass-revoked the live cohort**; it was caught during the re-port, not by review (#348 body). **Cost:** three features built twice; a near-miss on live data. **Cause:** no review loop to land work while fresh; no reviewer besides the author exists.

3.2 Squash-promote history split, paid twice

#325's squash promotion split `dev/main` histories; repair PR #328 (“rejoin histories after squash promotions”) was itself accidentally squash-merged and needed #330 minutes later; promote style then switched permanently to merge commits (main first-parent from #327 on). **Cost:** two repair PRs, plus a later `sync-main-into-dev-2` branch. **Cause:** promote procedure lives in oral tradition; the lesson is encoded nowhere (`docs/environments.md` still describes the old flow).

3.3 Premature merges losing work

#335 was squash-merged 44 seconds after opening with only 2 of its 4 commits pushed; a user-reported fix “never reached dev” until #337 cherry-picked it; #336 was closed as “Old.” Separately, merges race CI: #339 merged 72 seconds *before* its CI run finished; #354 went open-to-merge in 8 seconds; the same branch (`fix/luma-copy-polish`) was merged three times in one day (#338/#339/#340). **Cost:** lost commits, rescue cherry-picks, unreviewable history. **Cause:** merge is faster than the pipeline and nothing makes the pipeline blocking; CI cannot gate a merge that beats it.

3.4 Out-of-band database changes

Migration 00099’s content was applied to the dev database on 2026-07-31 under its *old* number (00092) before the file was renumbered; the dev ledger and the chain disagree again, and prod’s state for 00092–00100 is unrecorded (lane `13-lane-code-0809.md` §1). This is the same drift species that reached “prod eleven migrations behind” on 07-06 (`scripts/ops/prod-migration-repair-2026-07-06.sql`) and forced the 07-11 prod reset-and-rebuild — an event whose only record still sits on an unmerged branch (8a967dd). #77 (auto-apply migrations in CI), designed 2026-05-20 as the fix, remains open and untouched. **Cost:** July’s reset; the current landmine. **Cause:** manual apply ritual with no ledger reconciliation step and no automation.

3.5 Live-data surgery by one-off

An underfilled-pods closure for the *active* cycle was “handled with a manual one-off”; the SQL sits on unmerged branch `claude/close-underfilled-pods-fqq3g1` (commits through 08-04), never touches `cycle_enrollments`, and its own commit trail logs feedback #14 requesting a real admin/cron path (lane `13-lane-code-0809.md` §5). An earlier unmerged one-off (24610cf) would remove four participants from the current cycle. **Cost:** unauditable partial operations against live participant data. **Cause:** missing admin tooling for mid-cycle pod lifecycle events.

3.6 The tracker is a changelog, not a planning surface

One issue opened in twelve days (#357, filed 23 seconds before its own fix PR #358, whose “Fixes #.” link is broken — the issue is still open despite being fixed); zero issues closed; meanwhile ~18 decision-carrying statements shipped inside merged PR bodies with no ratification step (catalog: lane `12-lane-github-0809.md` §4; “O2” above is the exemplar). CODEOWNERS still requests review from an absent member and omits the person doing all the merging. **Cost:** decisions invisible to anyone not reading every PR; stale p1s; broken auto-close. **Cause:** at this speed, issues cost more than PRs — unless something (a template section, a weekly sweep) harvests decisions out of PR bodies.

3.7 Provenance hygiene

One commit from an unconfigured identity `t <t@t>` (263a0e4, 07-31); a shared org account (“HQ”) merging directly to `main` with no PR (5247a3e, 08-03, against the checked-in rule from 5640b08/#257); and, from the earlier window, 90 agent commits on `dev` with no attributable human. **Cost:** unanswerable “who decided this” questions — the exact question this audit spent most of its effort on. **Cause:** no enforcement, shared credentials, unconfigured machines.

4. Root cause, in one paragraph

Every item in §3 is a symptom of one structural fact: **a single operator working at high speed with advisory-only guardrails**. CI exists but does not gate; the branch rule exists but is not enforced; CODEOWNERS exists but points at the wrong people; the tracker exists but costs too much at this tempo; review exists as a concept the team built tooling for (agent reviewer roles, PR-template verify sections, after-the-fact audits) and never as a practice. The team repeatedly *noticed* — they wrote the rule (#257), built the migration-number guard, switched promote styles after #328 — but each lesson was learned by incident and encoded only partially. The strategy below therefore prioritizes *enforcement flips* and *decision-harvesting* over process ceremony: things that work when exactly one person is pushing code at 2am.

5. Forward strategy

Sized for the actual team; each phase is independently valuable.

5.1 Phase 0 — the enforcement flip (about two days, this week)

1. Enable branch protection on `dev` and `main`: PRs required, CI required to *complete and pass* before merge. This alone retires failure modes §3.2, §3.3, and the direct-to-main lane (§3.7). The rule already exists on paper (#257); this makes it real.
2. Fix CODEOWNERS: add the active release manager; remove or annotate the absent member so review requests stop routing into a void.
3. File the four missing issues (§2.3–§2.5 plus ledger reconciliation), close fixed-but-open #357, and re-anchor #212.
4. Hold one 90-minute ratification session: O2 (§2.6), #125, #213 cadence and labs semantics, the #302 pending-observations visibility default, and the 18 PR-body decisions. Output: a one-page decisions log committed to `docs/`.

5.2 Phase 1 — before the next cycle boundary (one to two weeks of part-time work)

1. **Ledger reconciliation**: confirm dev’s applied history for 00092→00099; confirm prod’s state for 00092–00100; record both in `docs/environments.md`; merge the prod-reset record (8a967dd) to mainline.
2. **Ship #77** (auto-apply migrations on merge, dev first) — the standing fix for §3.4, designed in May, roughly a day of work.
3. **Revocation live**: §2.4’s fail-closed guard, then §2.1’s dry-run week, then enable. Enrollment enforcement stops being dark.
4. **Erase migration** (§2.5): FK deletes + codified prod-only fixes, so every environment converges.
5. **Underfilled-pods admin path** (feedback #14): turn the one-off SQL into an owner-gated, audited admin action (the `owner_actions` pattern from 00078 already exists for exactly this).
6. **Blind-voting leak fix** (§2.3): one route, one test.

5.3 Phase 2 — structural (ongoing, low ceremony)

1. **Decision harvesting**: a “Decisions” section in the PR template that must be either “none” or copied into `docs/decisions/` at merge; a monthly 30-minute ratification sweep. This meets the team where decisions actually happen (PR bodies) instead of demanding issue-first discipline that twelve days of evidence says will not stick.
2. **Scoped human review**: require one human review only for PRs touching `lib/auth/`, `supabase/migrations/`, or participant-data surfaces; self-merge stays for copy, content, and UI polish. Narrow enough to survive a one-operator week; wide enough to have caught #313.
3. **Resolve the sensemaking fork** (#185 in-app port vs the #302 working-folder bridge) with explicit switch criteria — this is the biggest architecture decision currently drifting, and it determines where the next quarter of build effort goes.
4. **Hygiene cadence**: the 60-branch cleanup that happened this window becomes a monthly habit; git identities configured on all machines; the shared HQ account restricted to release operations via PRs.

6. Priority matrix

7. Reproducing the evidence

Full lane reports with command-level provenance: `olos-recon/2026-07-24/` on branch `claude/olos-reentry-audit-8bglhk` — `12-lane-github-0809.md` (PR stream, failure modes, review state, decision catalog), `13-lane-code-0809.md` (migrations 00092–00100, auth surface, unmerged branches), `14-RERUN-BRIEF-2026-08-09.md` (window synthesis), and lanes 01–07 for the June–July baseline. The branch is reference-only: never merged, safe to archive or delete.

#	Item	Evidence anchor	Severity	Effort	Phase
1	Branch protection + CI gating	#354, #339, 5247a3e	high	S	0
2	Ratification session (O2, #125, #213, #302, 18 items)	00100, lane 12 §4	high	S	0
3	File missing p1s; fix tracker state	cmt. 4941719186; #357	high	S	0
4	Ledger reconciliation (dev 00092/00099; prod 00092–00100)	lane 13 §1	high	S	1
5	Revocation cron fail-closed + dry-run + enable	4361f91; vercel.json	high	S–M	1
6	Erasure FK + codify prod-only fixes	runbook:171–178; 00058:74	high	S	1
7	#77 auto-apply migrations	#110 cmt.; repair SQL 07-06	high	M	1
8	Blind-voting leak fix	cmt. 4941719186	med-high	S	1
9	Underfilled-pods admin path	feedback #14; branch fqq3g1	med	M	1
10	Decision-harvesting practice	lane 12 §4	med	S	2
11	Scoped review policy	#313 near-miss	med	S	2
12	Sensemaking fork decision	#185 vs #302	med	decision	2